Høyskolen Kristiania

Bokmål

Emnekode:	**ETH2100**
Emnenavn:	**Etisk Hacking**
Vurderingskombinasjon:	**Mappevurdering, DEL 3**
Innleveringsdato:	**22. desember 2025**
Filformat:	**PDF (ingen vedlegg)**

Eksamen er en mappevurdering og består av 3 deler. Delene skal leveres som 3 forskjellige innleveringer i Wiseflow. Karakter blir satt basert på ALLE delene som en helhet, alle 3 delene må være bestått. Se første forelesning for detaljer om karaktersetting.

Del 3: EKSAMEN (14 dager, individuell, hjemmeeksamen)

- Besvarelsen leveres inn som PDF fil, det skal ikke leveres med vedlegg
- Filnavn skal være [kandidatnummer]_ETH2100_Eksamen_DEL3.pdf

Oppgavesettet består av 10 sider, og det er totalt 8 oppgaver som skal besvares.

Vær obs på at eksamen MÅ leveres innen fristen som er satt, og må leveres via eksamensplattformen WISEFLOW. Det vil ikke være mulig å få levert oppgaven etter fristen – det betyr at du bør levere i god tid slik at du kan ta kontakt med eksamenskontoret eller brukerstøtte hvis du har tekniske problemer.

Da dette er en hjemmeeksamen er det viktig å vise helhetlig forståelse, og oppgavene har et større preg av drøfting eller teknisk problemløsing. Det forventes derfor utfyllende og forklarende svar på alle teori oppgaver, og dokumentasjon i form av skjermbilder og tilhørende forklaringer til alle praktiske oppgaver. (Bilder som er vedlegg, men ikke satt inn i besvarelsen anses ikke som en del av besvarelsen.)

Det presiseres at studenten skal besvare eksamen selvstendig og individuelt, samarbeid mellom studenter og plagiat er ikke tillatt. Det er ikke tillatt å presentere andres arbeid som ditt eget – dette inkluderer arbeid utført av kunstig intelligens (som tekst- eller kode-genereringsmodeller). All bruk av tekst, bilder og illustrasjoner som er hentet fra forelesninger, lærebøker eller internett skal føres med kildehenvisning slik at det kommer tydelig frem hva som er studentens eget arbeid, APA7 standarden skal brukes for kilder. For topp score bør svarene underbygges med relevante kilder utover ordinær pensumlitteratur. Det bør selvsagt også refereres til pensumlitteratur når relevant.

OBS: De 4 teorioppgavene (oppgave 1 – 4) skal ikke være på mer enn 12 A4 sider, med font størrelse 12, normale marger og linjeavstand 1.0. I tillegg til teorioppgavene kommer de praktiske oppgavene (de praktiske oppgavene inngår ikke i sideantallet på 12 sider, som kun gjelder for teorioppgavene samlet).

Teori oppgaver og drøftinger

Oppgave 1 – Metodologi (10%)

Når man skal gjennomføre en revisjon av sikkerheten i en applikasjon eller et selskap er det viktig å følge en test-metodologi, for en etisk hacker er det derfor essensielt å kjenne de forskjellige typene for å kunne forstå hvilke som er best egnet til forskjellige oppgaver, og for å kunne velge en metodologi for et gitt oppdrag. Dette valget må også kunne kommuniseres til en oppdragsgiver. I denne oppgaven skal du vise at du kan bruke det du har lært om test-metodologi til å vurdere og sammenligne disse.

Svaret må underbygges med relevante kilder, minimum en av kildene må være fra emnets pensum (penumbok om Kali eller dokumentet fra Owasp). Besvarelser som ikke har korrekt oppgitt kildereferanser vil ikke oppnå poeng. Kildelisten skal oppgis for hver deloppgave separat.

Oppgaveformulering:

Forklar din testmetodikk under arbeidet med mappeleveringens Del 2. Drøft metodikken du valgte å bruke med annen relevant testmetodikk. Hvis du ikke valgte en testmetodikk fra et etablert rammeverk under ditt arbeid med Del 2 så kan du forklare hvordan du jobbet i praksis, drøfte hvilke deler av dette arbeidet som passer med relevante rammeverk – og så vurdere denne arbeidsformen opp mot testmetodikk som har vært pensum i dette emnet og drøfte fordeler og ulemper.

Oppgave 2 – Cyberspace (10%)

«Cybersikkerhet» tar mer og mer over som begrep for å forklare vår bransje, som også navnet på dette studiet viser, det er derfor viktig å forstå hva som ligger i dette begrepet, og å kunne drøfte forskjellene mellom begreper som «cyberspace» og «internett».

Svaret må underbygges med relevante kilder. Besvarelser som ikke har korrekt oppgitt kildereferanse på APA7 format vil ikke oppnå poeng, en av kildene må være «Forsvarets fellesoperative doktrine» og begrepene brukt der må drøftes opp mot andre kilder. Kildelisten skal oppgis for hver deloppgave separat.

Oppgaveformulering:

Drøft begrepene «cyberspace» og «cybersikkerhet», forklar bakgrunnen for begrepene og forklar hvorfor dette begrepet er viktig i rollen til en etisk hacker.

Oppgave 3 – Kunstig intelligens (15%)

Kunstig intelligens har gått fra å være et akademisk forskningsområde til å bli "allemannseie" etter fremveksten av LLM modeller som ChatGPT. For oss som jobber innen sikkerhet er ikke bare kunstig intelligens en "hjelper" – men det kan også medføre trusler og sårbarheter. Dette er det viktig at alle som jobber med sikkerhet har et reflektert forhold til.

Svaret må underbygges med relevante kilder, en av kildene må være forelesning nummer 10 fra uke 39, i tillegg må en kilde være artikkelen Agentic Autonomy Levels and Security (link fra samme forelesning). Besvarelser som ikke har korrekt oppgitt kildereferanser vil ikke oppnå poeng. Kildelisten skal oppgis for hver deloppgave separat.

Oppgaveformulering:

Drøft forskjellige sikkerhetsutfordringer som har blitt introdusert som en følge av kunstig intelligens, med spesiell fokus på generativ AI og agentisk AI.

Oppgave 4 – Analyse av hacker angrep (15%)

Som en etisk hacker vil man ofte bli bedt om en ekspertuttalelse om et hacker angrep eller en trussel-aktør som har fått fokus i media, du skal i denne oppgaven derfor vise at du er i stand til å tilegne deg ny kunnskap, sette dette i riktig kontekst, og forklare dette videre med egne ord.

I denne oppgaven skal du vise at du klarer å fordype deg i et emne, og raskt finne kilder med relevant informasjon.

På denne oppgaven må besvarelsen inneholde minimum en referanse til artikkelen som er linket under og minimum to andre referanser. Besvarelser som ikke har korrekt oppgitt kildereferanse på APA7 format vil ikke oppnå poeng. Kildelisten skal oppgis for hver deloppgave separat.

En oppdragsgiver sender deg følgende artikkel fra BBC World Service fra 10. mars 2025 (artikkelen er også lagt ved eksamensoppgaven på Canvas som PDF fil):

https://www.bbc.com/news/articles/c2kgndwwd7lo

Oppgaveformulering:

Sett deg inn i hacker gruppen som kalles Lazarus Group. Du som teknikker må også søke flere mer tekniske kilder på egenhånd og skrive en fyldig beskrivelse av gruppen. Din beskrivelse bør inneholde informasjon om HVEM denne gruppen er, en oversikt over HVA gruppen har stått bak, og HVORDAN denne gruppen opererer.

Du skal videre forklare for den tenkte oppdragsgiveren om dette er en trussel-aktør oppdragsgivers selskap, som er et norsk selskap innen kraftsektoren som eier flere vannkraftverk på Vestlandet, bør være spesielt redd for, og om de kan tenkes å rette angrep mot oppdragsgivers selskap.

Praktiske oppgaver

Oppgave 5 – Exploit med Metasploit (10%)

I denne oppgaven skal du vise at du kan gjennomføre et enkelt angrep med et exploit fra metasploit mot en sårbar server. Du skal demonstrere de faktiske verktøyene du bruker og dokumentere hvordan du har gått frem for å løse oppgaven, inklusive skjermbilder og kommandoer du har kjørt.

I denne oppgaven skal du bruke maskin med Kali Linux og Metasploit. Som «offer» maskin skal du bruke den virtuelle maskinen Metasploitable 2. Metasploitable 2 VMen skal være satt opp i henhold til øvingsoppgave i uke 37 (ETH2100_U37_Øvingsoppgaver_Pentest_Verktøy).

Oppgaveformulering:

Du skal først starte Metasploitable 2 VM. Denne oppgaven består av 3 steg.

Det første steget er at du skal kjøre NMAP mot alle porter på Metasploitable 2, og vise hvilken VERSJON av Unreal IRC server som kjører på den VMen. Dokumenter med skjermbilde av NMAP og forklar hvilket versjonsnummer du har funnet.

I steg to skal du fra Kali Linux starte verktøyet Metasploit, du skal ved hjelp av Metasploit starte et shell på «offer» maskinen ved hjelp av et exploit mot Unreal IRC serveren, og opprette en ny bruker. Brukernavnet skal være DITT kandidatnummer på denne eksamen, og med et valgfritt passord. *Du oppretter en ny bruker ved å skrive «sudo useradd -m -p $(openssl passwd -1 "sunshine") 700999» (etterfulgt av sudo passordet – som du i dette tilfellet vet er "msfadmin"), hvor 700999 erstattes av DITT kandidatnummer på denne eksamen.*

I det tredje steget skal du restarte Metasploitable 2 VMen og logge deg inn med den nyopprettede brukeren, dokumenter med skjermbilde av Metasploitable 2 at du har fått opprettet ny bruker.

Oppgave 6 – Passord brute-force (10%)

I denne oppgaven skal du vise at du kan gjennomføre et SQL Injection angrep for å hente ut passord hasher, for så å knekke disse passordene med John the Ripper. Du skal demonstrere de faktiske verktøyene du bruker og dokumentere hvordan du har gått frem for å løse oppgaven, inklusive skjermbilder og kommandoer du har kjørt.

I denne oppgaven skal du bruke maskin med Kali Linux. Som «offer» maskin skal du bruke den virtuelle maskinen Damn Vulnerable Web Application (DVWA). DVWA VMen skal være satt opp i henhold til øvingsoppgave i uke 36 (ETH2100_U36_Øvingsoppgaver_Kali_Virtlab)*.*

Oppgaveformulering:

Denne oppgaven består av 2 steg. I det første steget skal du utføre et SQL Injection angrep mot DVWA VMen for å hente ut passord hasher fra serveren. Du bestemmer selv fremgangsmåten, men angrepet må utføres manuelt (og ikke for eksempel med sqlmap).

I det neste steget skal du bruke verktøyet John the Ripper i Kali Linux for å knekke passordene med en standard wordlist som du har hentet fra Kali Linux.

Oppgave 7 – ShellShock – pwnOS (15%)

I denne oppgaven skal du vise at du kan gjennomføre et avansert angrep med Shellshock sårbarheten mot den sårbare maskinen PwnOS.

Spesifikt er PwnOS sårbar ovenfor CVE-2014-6271, du skal bruke den sårbarheten til å legge til «vmware» brukeren til sudoers listen (`echo "vmware ALL=(ALL) ALL" >> /etc/sudoers`*), slik at du kan oppnå root på maskinen.*
https://en.wikipedia.org/wiki/Shellshock_%28software_bug%29

Du vil i denne oppgaven bli utfordret på å kombinere flere forskjellige teknikker for å oppnå shell tilgang med root privilegier på en server. Du står ganske fritt til å velge fremgangsmåte,

men en del av angrepet ditt <u>må være</u> at du utnytter Shellshock (CVE-2014-6271) gjennom en HTTP request for å legge til vmware til sudoers listen. Resten av fremgangsmåten bestemmer du selv, du må dokumentere fremgangsmåten med skjermbilder av de involverte maskinene og verktøy du bruker, og forklare hvordan du kom frem til denne fremgangsmetoden.

I denne oppgaven skal du bruke maskin med Kali Linux, og som «offer» maskin skal du bruke den virtuelle maskinen PwnOS. PwnOS VMen skal være satt opp i henhold til øvingsoppgave i uke 44
(ETH2100_U44_Øvingsoppgaver_PasswordEqualsGod.pptx),
se for øvrig ytterligere forklaringer fra forelesning 20 fra samme uke.

Oppgaveformulering:

Du skal starte opp PwnOS VM. Kjør først et portscan av maskinen, dokumenter at du har testet ALLE åpne porter med et skjermbilde eller annen logg fra nmap. Hvilken porter er åpne?

Du skal så opprette en CGI fil inne på serveren, du kan selv velge hvilken sårbarhet du skal bruke for å få opprettet filen lokalt på serveren (men må ikke kreve root), og så skal du trigge Shellshock sårbarheten, med Shellshock skal du <u>legge til vmware som sudoer</u> (se over).

Navnet på CGI filen må være [kandidatnummer].cgi, for eksempel 700999.cgi, dette må dokumenteres med skjermbilder både når du oppretter filen, og når du kaller den senere gjennom en HTTP request for å trigge Shellshock.

For å demonstrere at du nå har oppnådd rettigheter på serveren som «root» skal du nå koble deg til SSH med brukernavn vmware (passordet for denne brukeren er h4ckm3, du skal slippe å bruke tid på å knekke dette passordet). Ved å bruke <u>sudo su</u> skal du elevere brukeren til root – og så skal du skrive ut innholdet av filen /etc/shadow (til skjerm).

I besvarelsen skal du vise kjøring og resultat av utnyttelse av Shellshock sårbarheten, og vise med skjermbilde at du får frem innholdet av shadow filen.

Oppgave 8 – Pivoting og PrivEsc (15%)

I denne oppgaven skal du vise at du kan gjennomføre et avansert angrep hvor du skal gjennomføre «pivot» (lateral movement) for å flytte deg fra den første sårbare serveren til en annen server på innsiden av nettverket. Du skal også oppnå «Manager» rettigheter.

Du skal videre demonstrere at du klarer å håndtere verktøy som kan brukes i et redteam oppdrag for å unngå at du blir oppdaget av sensorene til et Security Operations Center.

Oppgaven består av flere faser, og det er spesifikke krav til hver fase for å simulere angrepet, du skal demonstrere de faktiske verktøyene du bruker og dokumentere hvordan du har gått frem for å løse oppgaven, inklusive skjermbilder og kommandoer du har kjørt. Hvert del skal ha en underoverskrift i besvarelsen som «Del A», «Del B» og så videre, og fasene bygger på hverandre som gjør at de må gjøres i riktig rekkefølge.

I denne oppgaven skal du bruke maskin med Kali Linux. Som «offer» maskin «nummer 1» skal du bruke den virtuelle maskinen «Bengts Windows VM». Windows VMen skal være satt opp i henhold til øvingsoppgave i uke 37 (ETH2100_U37_Øvingsoppgaver_Pentest_Verktøy), slide 64 til 78. *I tillegg skal VMen ha tilleggsprogramvare og konfigurasjon som satt opp i:*

- *uke 42 (*ETH2100_U42_Øvingsoppgaver_IntoTheRabbitHole_Exploits*), slide 8 til 10,*
- *uke 44 (*ETH2100_U44_Øvingsoppgaver_PasswordEqualsGod*) slide 6 til 12, og*
- *uke 45 (*ETH2100_U45_Øvingsoppgaver_DeeperIntoTheRabbitHole*) slide 7 til 25.*

Som «offer» maskin «nummer 2» skal du bruke den virtuelle maskinen Metasploitable 2. Metasploitable 2 VMen skal være satt opp i henhold til øvingsoppgave i uke 37 (ETH2100_U37_Øvingsoppgaver_Pentest_Verktøy).

Disse to virtuelle maskinene må være koblet til det samme nettverket, og standard oppsett for VmWare forventes brukt (hvor VmWare simulerer en multiport repeater tilsvarende slik en Hub fungerer). Hvis du har gjort tilpasninger eller endringer i nettverksoppsettet du bruker i ditt lab-miljø må du ta hensyn til dette for å være i stand til å fullføre oppgaven.

Oppgaveformulering:

DEL A (første fase i angrepet)

Du skal starte opp Windows VM, og logge deg inn som Administrator. På Windows VMen har du selv satt passord for Administrator bruker (det er tinkerbell hvis du har samme passord som satt i øvingsoppgavene). Denne virtuelle maskinen er sårbar ovenfor en sårbarhet som heter EternalBlue.

Det første steget er at du skal kjøre NMAP mot VM for å sjekke om serveren er sårbar ovenfor EternalBlue sårbarheten (hint: et script i nmap kan gjøre dette).

Fra Kali Linux skal du starte verktøyet Metasploit, du skal gjennom Metasploit utnytte EternalBlue sårbarhet på Windows VMen. Du skal utnytte sårbarheten til å sette opp remote execution (psexec), eller et reverse shell mot serveren.

DEL B (andre fase i angrepet)

Du skal så finne et verktøy som allerede er installert i Windows som kan utnyttes for å gjennomføre Packet Capture på nettverket. Dette skal ha tilsvarende effekt som å installere Wireshark – men det spesifiseres at studenten ikke har lov til å laste ned Wireshark på Windows VMen (og heller ikke bruke Wireshark hvis studenten har installert det der allerede under øvingstimene – i denne simuleringen vil bruk av Wireshark i denne delen trigge en alarm). Dette verktøyet skal settes i capture modus, og verktøyet må startes gjennom Metasploit fra Del A.

DEL C (simulering av aktivitet fra bruker)

Du skal så starte opp Metasploitable 2 VMen.
Fra Windows VMen skal du starte en TELNET klient (da det er pivot fra denne maskinen vi nå simulerer). Du skal skrive inn IP adressen til Metasploitable 2 og koble deg til telnet porten med brukernavn msfadmin og passordet msfadmin.

Telnet klient er sannsynligvis ikke installert på Windows VMen så dette må du installere manuelt som en del av dette steget (dette anses som normal brukeraktivitet), for eksempel kan du velge Putty telnet klienten.

DEL D (tredje og siste fase i angrepet)

For å avslutte angrepet skal du nå hente ut Packet Capture fra Windows VMen, det må gjøres gjennom Metasploit du brukte i Del A, men ellers er fremgangsmåten valgfri. Det er opp til deg hvordan du ønsker å gjøre det og hvor du ønsker å eksfiltere data til – men det presiseres at det må gjøres gjennom Metasploit (og for eksempel ikke ved å logge inn «fysisk» på Windows.)

Du skal konvertere denne Packet Capture filen til å bli kompatibel med PCAP filformatet, og skal så åpne filen i Wireshark. Dette kan gjøres på host maskinen eller i Kali Linux. I Wireshark skal du finne pakken(e) som inneholder innloggingen og dokumentere med skjermbilde at du har funnet passordet i klartekst – og med det demonstrere at du har gjennomført elevering av privilegier (til administrator rollen på offer «maskin 2»).

-

Slutt på oppgavesettet

Høyskolen Kristiania

Nynorsk

Emnekode:	**ETH2100**
Emnenamn:	**Etisk hacking**
Vurderingskombinasjon:	**Mappevurdering, DEL 3**
Innleveringsdato:	**22. desember 2025**
Filformat:	**PDF (ingen vedlegg)**

Eksamen er ei mappevurdering og består av 3 delar. Delane skal leverast som 3 ulike innleveringar i Wiseflow. Karakter blir sett basert på ALLE delane som ein heilskap, alle 3 delane må vere beståtte. Sjå første førelesing for detaljar om karaktersetjing.

Del 3: EKSAMEN (14 dagar, individuell, heimeeksamen)

- Svaret leverast inn som PDF-fil, det skal ikkje leverast med vedlegg
- Filnamn skal vere [kandidatnummer]_ETH2100_Eksamen_DEL3.pdf

Oppgåvesettet består av 10 sider, og det er totalt 8 oppgåver som skal svarast på.

Ver obs på at eksamen MÅ leverast innan fristen som er sett, og må leverast via eksamensplattforma WISEFLOW. Det vil ikkje vere mogleg å få levert oppgåva etter fristen – det betyr at du bør levere i god tid slik at du kan ta kontakt med eksamenskontoret eller brukarstøtte om du har tekniske problem.

Då dette er ein heimeeksamen er det viktig å vise heilskapleg forståing, og oppgåvene har eit større preg av drøfting eller teknisk problemløsing. Det blir derfor forventa utfyllande og forklarande svar på alle teorioppgåver, og dokumentasjon i form av skjermbilde og tilhøyrande forklaringar til alle praktiske oppgåver. (Bilde som er vedlegg, men ikkje sett inn i svaret blir ikkje rekna som ein del av svaret.)

Det blir presisert at studenten skal svare på eksamen sjølvstendig og individuelt, samarbeid mellom studentar og plagiat er ikkje tillate. Det er ikkje tillate å presentere andre sitt arbeid som ditt eige – dette inkluderer arbeid utført av kunstig intelligens (som tekst- eller kode-genereringsmodellar). All bruk av tekst, bilde og illustrasjonar som er henta frå førelesingar, lærebøker eller internett skal førast med kjeldetilvising slik at det kjem tydeleg fram kva som er studenten sitt eige arbeid, APA7-standarden skal brukast for kjelder. For topp score bør svara underbyggast med relevante kjelder utover ordinær pensumlitteratur. Det bør sjølvsagt òg refererast til pensumlitteratur når dette er relevant.

OBS: Dei 4 teorioppgåvene (oppgåve 1 – 4) skal ikkje vere på meir enn 12 A4-sider, med fontstorleik 12, normale margar og linjeavstand 1.0. I tillegg til teorioppgåvene kjem dei praktiske oppgåvene (dei praktiske oppgåvene inngår ikkje i sidetalet på 12 sider, som berre gjeld for teorioppgåvene samla).

Teori oppgåver og drøftingar

Oppgåve 1 – Metodologi (10 %)

Når ein skal gjennomføre ein revisjon av tryggleiken i ein applikasjon eller eit selskap er det viktig å følgje ein test-metodologi, for ein etisk hackar er det difor essensielt å kjenne dei ulike typane for å kunne forstå kva som er best eigna til ulike oppgåver, og for å kunne velje ein metodologi for eit gjeve oppdrag. Dette valet må også kunne kommuniserast til ein oppdragsgjevar. I denne oppgåva skal du vise at du kan bruke det du har lært om test-metodologi til å vurdere og samanlikne desse.

Svaret må underbyggjast med relevante kjelder, minimum ei av kjeldene må vere frå pensumet i emnet (pensumbok om Kali eller dokumentet frå Owasp). Svar som ikkje har korrekt gjeve opp kjeldereferanser vil ikkje oppnå poeng. Kjeldelista skal gjevast opp for kvar deloppgåve separat.

Oppgåveformulering:

Forklar testmetodikken din under arbeidet med mappeleveringas Del 2. Drøft metodikken du valde å bruke med annan relevant testmetodikk. Viss du ikkje valde ein testmetodikk frå eit etablert rammeverk under arbeidet ditt med Del 2, kan du forklare korleis du jobba i praksis, drøfte kva delar av dette arbeidet som passar med relevante rammeverk – og så vurdere denne arbeidsforma opp mot testmetodikk som har vore pensum i dette emnet og drøfte fordelar og ulemper.

Oppgåve 2 – Cyberspace (10 %)

«Cybersikkerheit» tar meir og meir over som omgrep for å forklare bransjen vår, som også namnet på dette studiet viser, det er difor viktig å forstå kva som ligg i dette omgrepet, og å kunne drøfte forskjellane mellom omgrep som «cyberspace» og «internett».

Svaret må underbyggast med relevante kjelder. Svar som ikkje har korrekt gjeve opp kjeldereferanse på APA7-format vil ikkje oppnå poeng, ei av kjeldene må vere «Forsvarets fellesoperative doktrine» og omgrepa brukte der må drøftast opp mot andre kjelder. Kjeldelista skal gjevast opp for kvar deloppgåve separat.

Oppgåveformulering:

Drøft omgrepa «cyberspace» og «cybersikkerheit», forklar bakgrunnen for omgrepa og forklar kvifor dette omgrepet er viktig i rolla til ein etisk hackar.

Oppgåve 3 – Kunstig intelligens (15 %)

Kunstig intelligens har gått frå å vere eit akademisk forskingsområde til å bli "allemannseige" etter framveksten av LLM-modellar som ChatGPT. For oss som jobbar innan tryggleik er ikkje berre kunstig intelligens ein "hjelpar" – men det kan også medføre trugsmål og sårbarheiter. Dette er det viktig at alle som jobbar med tryggleik har eit reflektert tilhøve til.

Svaret må underbyggjast med relevante kjelder, ei av kjeldene må vere førelesing nummer 10 frå veke 39, i tillegg må ei kjelde vere artikkelen Agentic Autonomy Levels and Security (link frå same førelesing). Svar som ikkje har korrekt gjeve opp kjeldereferanse vil ikkje oppnå poeng. Kjeldelista skal gjevast opp for kvar deloppgåve separat.

Oppgåveformulering:

Drøft ulike tryggingsutfordringar som har blitt introduserte som følgje av kunstig intelligens, med spesiell fokus på generativ KI og agentisk KI.

Oppgåve 4 – Analyse av hackarangrep (15 %)

Som ein etisk hackar vil ein ofte bli beden om ei ekspertutsegn om eit hackarangrep eller eit trugsmålsaktør som har fått fokus i media, du skal i denne oppgåva difor vise at du er i stand til å tileigne deg ny kunnskap, setje dette i riktig kontekst, og forklare dette vidare med eigne ord.

I denne oppgåva skal du vise at du greier å fordjupe deg i eit emne, og raskt finne kjelder med relevant informasjon.

På denne oppgåva må svaret ditt innehalde minimum ein referanse til artikkelen som er linka under og minimum to andre referansar. Svar som ikkje har korrekt gjeve opp kjeldereferanse på APA7-format vil ikkje oppnå poeng. Kjeldelista skal gjevast opp for kvar deloppgåve separat.

Ein oppdragsgjevar sender deg følgjande artikkel frå BBC World Service frå 10. mars 2025 (artikkelen er også lagd ved eksamensoppgåva på Canvas som PDF-fil):

https://www.bbc.com/news/articles/c2kgndwwd7lo

Oppgåveformulering:

Set deg inn i hackargruppa som blir kalla Lazarus Group. Du som teknikar må òg søkje fleire meir tekniske kjelder på eiga hand, og skrive ei fyldig skildring av gruppa. Skildringa di bør innehalde informasjon om KVEN denne gruppa er, ei oversikt over KVA gruppa har stått bak, og KORLEIS denne gruppa opererer.

Du skal vidare forklare for den tenkte oppdragsgjevaren om dette er ein trugsmåls-aktør som selskapet til oppdragsgjevaren, som er eit norsk selskap innan kraftsektoren som eig fleire vasskraftverk på Vestlandet, bør vere spesielt redd for, og om dei kan tenkjast å rette angrep mot selskapet til oppdragsgjevar.

Praktiske oppgåver

Oppgåve 5 – Exploit med Metasploit (10 %)

I denne oppgåva skal du vise at du kan gjennomføre eit enkelt angrep med eit exploit frå metasploit mot ein sårbar sørvar. Du skal demonstrere dei faktiske verktøya du brukar og dokumentere korleis du har gått fram for å løyse oppgåva, inklusive skjermbilde og kommandoar du har køyrt.

I denne oppgåva skal du bruke maskin med Kali Linux og Metasploit. Som «offer»-maskin skal du bruke den virtuelle maskina Metasploitable 2. Metasploitable 2 VMen skal vere sett opp i samsvar med øvingsoppgåve i veke 37 (ETH2100_U37_Øvingsoppgaver_Pentest_Verktøy).

Oppgåveformulering:

Du skal først starte Metasploitable 2 VM. Denne oppgåva består av 3 steg.

Det første steget er at du skal køyre NMAP mot alle portar på Metasploitable 2, og vise kva VERSJON av Unreal IRC-sørvar som køyrer på den VM-en. Dokumenter med skjermbilde av NMAP og forklar kva versjonsnummer du har funne.

I steg to skal du frå Kali Linux starte verktøyet Metasploit, du skal ved hjelp av Metasploit starte eit shell på «offer»-maskina ved hjelp av eit exploit mot Unreal IRC-sørvaren, og opprette ein ny brukar. Brukarnamnet skal vere DITT kandidatnummer på denne eksamenen, og med eit valfritt passord. *Du opprettar ein ny brukar ved å skrive «sudo useradd -m -p $(openssl passwd -1 "sunshine") 700999» (etterfølgd av sudo passordet – som du i dette tilfellet veit er "msfadmin"), der 700999 blir erstatta av kandidatnummeret DITT på denne eksamenen.*

I det tredje steget skal du restarte Metasploitable 2 VM-en og logge deg inn med den nyoppretta brukaren, dokumenter med skjermbilde av Metasploitable 2 at du har fått oppretta ny brukar.

Oppgåve 6 – Passord brute-force (10 %)

I denne oppgåva skal du vise at du kan gjennomføre eit SQL Injection angrep for å hente ut passord hasher, for så å knekke desse passorda med John the Ripper. Du skal demonstrere at du meistrar oppsett, konfigurasjon og deployering av BeeF-verktøyet, og du skal dokumentere korleis du har gått fram for å løyse oppgåva, inklusive skjermbilde og kommandoar du har køyrt.

I denne oppgåva skal du bruke maskin med Kali Linux. Som «offer»-maskin skal du bruke den virtuelle maskina Damn Vulnerable Web Application (DVWA). DVWA VM-en skal vere sett opp i samsvar med øvingsoppgåve i veke 36 (ETH2100_U36_Øvingsoppgaver_Kali_VirtLab.pptx).

Oppgåveformulering:

Denne oppgåva består av 2 steg. I det første steget skal du utføre eit SQL Injection angrep mot DVWA VM-en for å hente ut passord hasher frå sørvaren. Du bestemmer sjølv framgangsmåten, men angrepet må utførast manuelt (og ikkje til dømes med sqlmap).

I det neste steget skal du bruke verktøyet John the Ripper i Kali Linux for å knekkje passorda med ei standard wordlist som du har henta frå Kali Linux.

Oppgåve 7 – ShellShock – pwnOS (15 %)

I denne oppgåva skal du vise at du kan gjennomføre eit avansert angrep med Shellshock sårbarheita mot den sårbare maskina PwnOS.

Spesifikt er PwnOS sårbar ovanfor CVE-2014-6271, du skal bruke den sårbarheita til å leggje til «vmware»-brukaren til sudoers lista (`echo "vmware ALL=(ALL) ALL" >> /etc/sudoers`*), slik at du kan oppnå root på maskina.*
https://en.wikipedia.org/wiki/Shellshock_%28software_bug%29

Du vil i denne oppgåva bli utfordra på å kombinere fleire ulike teknikkar for å oppnå shell tilgang med root privilegium på ein sørvar. Du står ganske fritt til å velje framgangsmåte, men ein del av angrepet ditt må vere at du utnyttar Shellshock (CVE-2014-6271) gjennom ein HTTP request for å leggje til vmware til sudoers lista. Resten av framgangsmåten bestemmer du sjølv, du må dokumentere framgangsmåten med skjermbilde av dei involverte maskinene og verktøy du brukar, og forklare korleis du kom fram til denne framgangsmetoden.

I denne oppgåva skal du bruke maskin med Kali Linux, og som «offer»-maskin skal du bruke den virtuelle maskina PwnOS. PwnOS VM-en skal vere sett opp i samsvar med øvingsoppgåve i veke 44
(ETH2100_U44_Øvingsoppgaver_PasswordEqualsGod.pptx),
sjå elles ytterlegare forklaringar frå førelesing 20 frå same veke.

Oppgåveformulering:

Du skal starte opp PwnOS VM. Køyr først eit portscan av maskina, dokument at du har testa ALLE opne portar med eit skjermbilede eller annan logg frå nmap. Kva porter er opne?

Du skal så opprette ei CGI-fil inne på sørvaren, du kan sjølv velje kva sårbarheit du skal bruke for å få oppretta fila lokalt på sørvaren (men må ikkje krevje root), og så skal du trigge Shellshock sårbarheita, med Shellshock skal du leggje til vmware som sudoer (sjå over).

Namnet på CGI-fila må vere [kandidatnummer].cgi, til dømes 700999.cgi, dette må dokumenterast med skjermbilete både når du opprettar fila, og når du kallar den seinare gjennom ein HTTP request for å trigge Shellshock.

For å demonstrere at du no har oppnådd rettar på sørvaren som «root», skal du no kople deg til SSH med brukarnamn vmware (passordet for denne brukaren er h4ckm3, du skal sleppe å bruke tid på å knekke dette passordet). Ved å bruke sudo su skal du elevere brukaren til root – og så skal du skrive ut innhaldet av fila /etc/shadow (til skjerm).

I svaret skal du vise køyring og resultat av utnytting av Shellshock sårbarheita, og vise med skjermbilde at du får fram innhaldet av shadow fila.

Oppgåve 8 – Pivoting og PrivEsc (15 %)

I denne oppgåva skal du vise at du kan gjennomføre eit avansert angrep der du skal gjennomføre «pivot» (lateral movement) for å flytte deg frå den første sårbare sørvaren til ein annan sørvar på innsida av nettverket. Du skal òg oppnå «Manager»-rettar.

Du skal vidare demonstrere at du greier å handtere verktøy som kan brukast i eit redteam-oppdrag for å unngå at du blir oppdaga av sensorane til eit Security Operations Center.

Oppgåva består av fleire fasar, og det er spesifikke krav til kvar fase for å simulere angrepet, du skal demonstrere dei faktiske verktøya du brukar og dokumentere korleis du har gått fram for å løyse oppgåva, inklusive skjermbilde og kommandoar du har køyrt. Kvar del skal ha ei underoverskrift i svaret ditt som «Del A», «Del B» og så vidare, og fasane byggjer på kvarandre som gjer at dei må gjerast i riktig rekkefølgje.

I denne oppgåva skal du bruke maskin med Kali Linux. Som «offer»-maskin «nummer 1» skal du bruke den virtuelle maskina «Bengts Windows VM». Windows VMen skal vere sett opp i samsvar med øvingsoppgåve i veke 37 (ETH2100_U37_Øvingsoppgaver_Pentest_Verktøy), slide 64 til 78*. I tillegg skal VMen ha tilleggsprogramvare og konfigurasjon som sett opp i:*

- *veke 42 (*ETH2100_U42_Øvingsoppgaver_IntoTheRabbitHole_Exploits*), slide 8 til 10,*
- *veke 44 (*ETH2100_U44_Øvingsoppgaver_PasswordEqualsGod*) slide 6 til 12, og*
- *veke 45 (*ETH2100_U45_Øvingsoppgaver_DeeperIntoTheRabbitHole*) slide 7 til 25.*

Som «offer»-maskin «nummer 2» skal du bruke den virtuelle maskina Metasploitable 2. Metasploitable 2 VM-en skal vere sett opp i samsvar med øvingsoppgåve i veke 37 (ETH2100_U37_Øvingsoppgaver_Pentest_Verktøy).

Desse to virtuelle maskinene må vere kopla til det same nettverket, og standard oppsett for VmWare blir forventa brukt (der VmWare simulerer ein multiport repeatar tilsvarande slik ein

Hub fungerer). Om du har gjort tilpassingar eller endringar i nettverksoppsettet du brukar i ditt lab-miljø må du ta omsyn til dette for å vere i stand til å fullføre oppgåva.

Oppgåveformulering:

DEL A (første fase i angrepet)

Du skal starte opp Windows VM, og logge deg inn som Administrator. På Windows VM-en har du sjølv sett passord for Administrator brukar (det er tinkerbell om du har same passord som sett i øvingsoppgåvene). Denne virtuelle maskina er sårbar ovanfor ei sårbarheit som heiter EternalBlue.

Det første steget er at du skal køyre NMAP mot VM for å sjekke om sørvaren er sårbar ovanfor EternalBlue-sårbarheita (hint: eit script i nmap kan gjere dette).

Frå Kali Linux skal du starte verktøyet Metasploit, du skal gjennom Metasploit utnytje EternalBlue-sårbarheit på Windows VMen. Du skal utnytje sårbarheita til å setje opp remote execution (psexec), eller eit reverse shell mot sørvaren.

DEL B (andre fase i angrepet)

Du skal så finne eit verktøy som allereie er installert i Windows som kan utnyttast for å gjennomføre Packet Capture på nettverket. Dette skal ha tilsvarande effekt som å installere Wireshark – men det blir spesifisert at studenten ikkje har lov til å laste ned Wireshark på Windows VMen (og heller ikkje bruke Wireshark om studenten har installert det der allereie under øvingstimane – i denne simuleringa vil bruk av Wireshark i denne delen trigge ein alarm). Dette verktøyet skal setjast i capture modus, og verktøyet må startast gjennom Metasploit frå Del A.

DEL C (simulering av aktivitet frå brukar)

Du skal så starte opp Metasploitable 2 VM-en.
Frå Windows VM-en skal du starte ein TELNET-klient (då det er pivot frå denne maskina vi no simulerer). Du skal skriv inn IP-adressa til Metasploitable 2 og kople deg til telnet porten med brukarnamn msfadmin og passordet msfadmin.

Telnet klient er sannsynlegvis ikkje installert på Windows VM-en så dette må du installere manuelt som ein del av dette steget (dette blir rekna som normal brukaraktivitet), til dømes kan du velje Putty telnet klienten.

DEL D (tredje og siste fase i angrepet)

For å avslutte angrepet skal du no hente ut Packet Capture frå Windows VMen, det må gjerast gjennom Metasploit du brukte i Del A, men elles er framgangsmåten valfri. Det er opp til deg korleis du ønskjer å gjere det og kvar du ønskjer å eksfiltere data til – men det blir presisert at det må gjerast gjennom Metasploit (og til dømes ikkje ved å logge inn «fysisk» på Windows.)

Du skal konvertere denne Packet Capture-fila til å bli kompatibel med PCAP-filformatet, og skal så opne fila i Wireshark. Dette kan gjerast på host-maskina eller i Kali Linux. I Wireshark skal du finne pakka/ene som inneheld innloggingа og dokumentere med skjermbilde at du har funne passordet i klartekst – og med det demonstrere at du har gjennomført elevering av privilegium (til administrator-rolla på offer «maskin 2»).

-

Slutt på oppgåvesettet.